

Seguridad Perimetral

Seguridad Perimetral

- La seguridad perimetral es un componente esencial de la seguridad informática que se centra en proteger la red de una organización desde el exterior. Su objetivo principal es prevenir o mitigar las amenazas que provienen de fuentes externas y mantener la integridad, confidencialidad y disponibilidad de los recursos de la red.

Componentes

- Firewall
- Filtrado de contenido
- VPN
- SIEM, IDS/IPS (Sistemas de Detección/Prevención de Intrusiones)
- Seguridad en el Correo Electrónico
- Gestión de Acceso
- Servidor Proxy
- Monitoreo y Registro
- Honeypots
- Sistemas anti-DDoS

Firewall

Son dispositivos que analizan los paquetes que circulan entre la red interna y la externa y los aceptan o los rechazan según unas reglas predefinidas.

Tipos:

1. Firewall de Filtro de Paquetes (Packet Filtering Firewall):
2. Firewall de Estado (Stateful Firewall)
3. Firewall de Inspección de Capa de Aplicación (Proxy Firewall o Application Layer Firewall)
4. Firewall de Filtrado de Contenido (Content Filtering Firewall)
5. Firewall de Próxima Generación (Next-Generation Firewall - NGFW)
6. Firewall de Hardware y Software

VPN

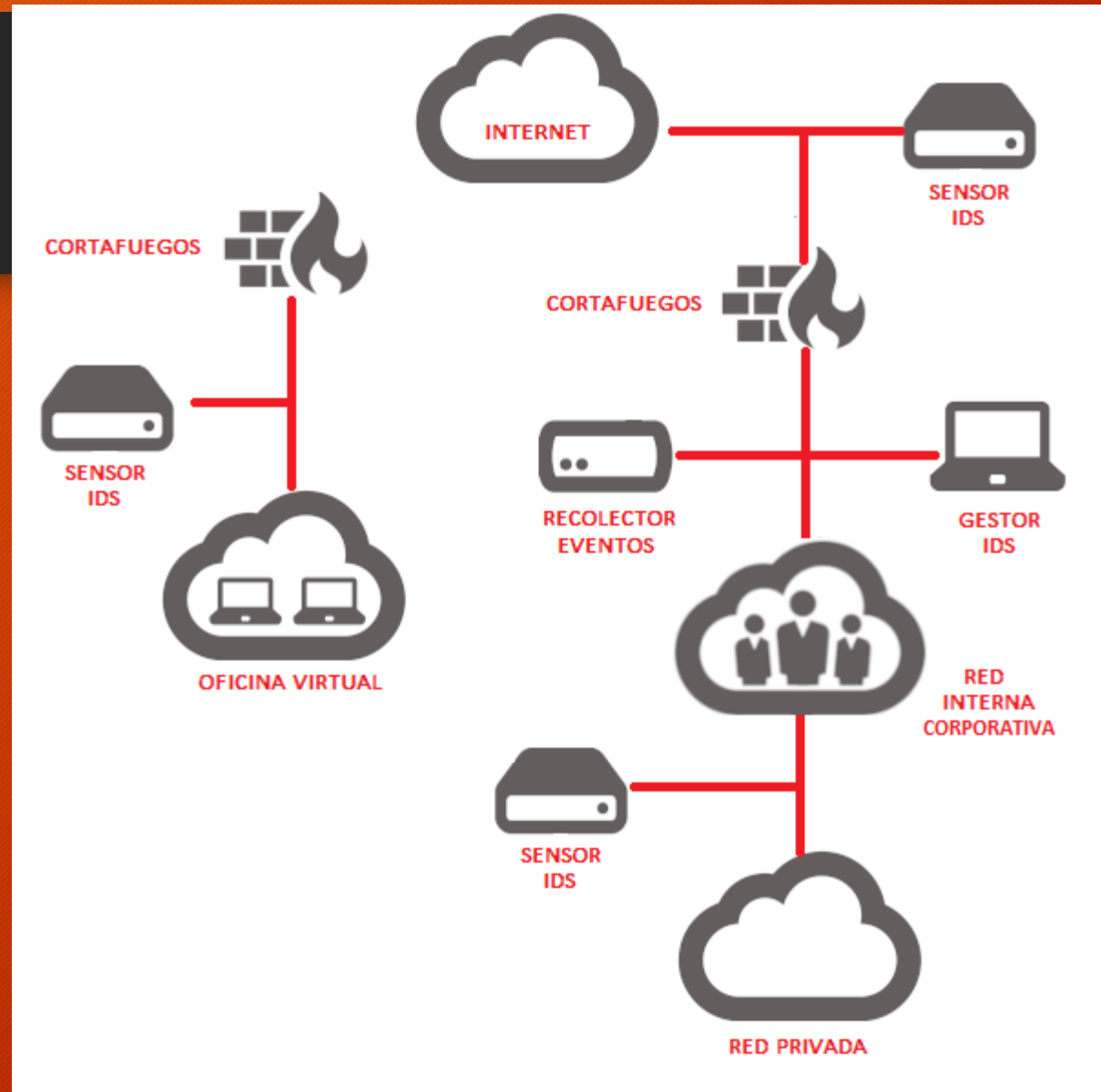
Una VPN, o Red Privada Virtual (por sus siglas en inglés, Virtual Private Network), es una tecnología que crea una conexión segura y cifrada a través de una red pública, como Internet. Esta conexión permite a los usuarios acceder a recursos y servicios de red de forma remota como si estuvieran directamente conectados a la red privada de la organización. La principal finalidad de una VPN es proporcionar un nivel adicional de seguridad y privacidad en las comunicaciones en línea.

Aquí hay algunos conceptos clave relacionados con las VPN:

- 1. Túneles Seguros**
- 2. Cifrado de Datos**
- 3. Acceso Remoto**
- 4. Anonimato y Privacidad**
- 5. Bypass de Restricciones Geográficas**
- 6. Seguridad en Redes Públicas**
- 7. Protocolos VPN:** OpenVPN, IPSec, L2TP/IPSec, PPTP, entre otros

SIEM, IPS IDS

Son sistemas de protección de las comunicaciones que actúan monitorizando el tráfico que entra o sale de nuestra red pero cada uno tiene unas características que les confieren ventajas e inconvenientes. Veremos estas diferencias y el papel de cada uno en la ciberseguridad de la empresa.



SIEM

- SIEM (Security Information and Event Management) o sistema de gestión de eventos e información de seguridad: es una solución híbrida centralizada que engloba la gestión de información de seguridad (Security Information Management) y la gestión de eventos (Security Event Manager). La tecnología SIEM proporciona un análisis en tiempo real de las alertas de seguridad generadas por los distintos dispositivos hardware y software de la red. Recoge los registros de actividad (logs) de los distintos sistemas, los relaciona y detecta eventos de seguridad, es decir, actividades sospechosas o inesperadas que pueden suponer el inicio de un incidente, descartando los resultados anómalos, también conocidos como falsos positivos y generando respuestas acordes en base a los informes y evaluaciones que registra, es decir, es una herramienta en la que se centraliza la información y se integra con otras herramientas de detección de amenazas.

IPS

- IPS (Intrusion Prevention System) o sistema de prevención de intrusiones: es un software que se utiliza para proteger a los sistemas de ataques e intrusiones. Su actuación es preventiva. Estos sistemas llevan a cabo un análisis en tiempo real de las conexiones y los protocolos para determinar si se está produciendo o se va a producir un incidente, identificando ataques según patrones, anomalías o comportamientos sospechosos y permitiendo el control de acceso a la red, implementando políticas que se basan en el contenido del tráfico monitorizado, es decir, el IPS además de lanzar alarmas, puede descartar paquetes y desconectar conexiones.
- Muchos proveedores ofrecen productos mixtos, llamándolos IPS/IDS, integrándose frecuentemente con cortafuegos y UTM (en inglés Unified Threat Management o Gestión Unificada de Amenazas) que controlan el acceso en función de reglas sobre protocolos y sobre el destino u origen del tráfico.

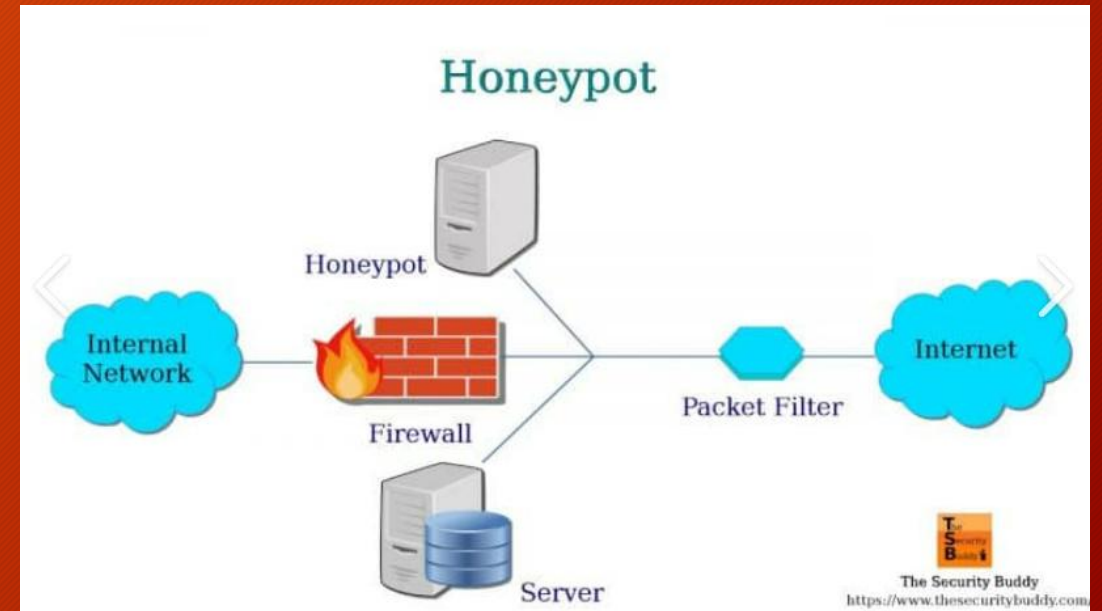
IDS

- IDS (Intrusion Detection System) o sistema de detección de intrusiones: es una aplicación usada para detectar accesos no autorizados a un ordenador o a una red, es decir, son sistemas que monitorizan el tráfico entrante y lo cotejan con una base de datos actualizada de firmas de ataque conocidas. Ante cualquier actividad sospechosa, emiten una alerta a los administradores del sistema quienes han de tomar las medidas oportunas. Estos accesos pueden ser ataques esporádicos realizados por usuarios malintencionados o repetidos cada cierto tiempo, lanzados con herramientas automáticas. Estos sistemas sólo detectan los accesos sospechosos emitiendo alertas anticipatorias de posibles intrusiones, pero no tratan de mitigar la intrusión. Su actuación es reactiva.

Honeypots

Los "honeypots" son parte de un concepto más amplio llamado "honeypots". Un honeypot es una trampa de seguridad diseñada para atraer y detectar a los atacantes cibernéticos. Los honeypots simulan ser sistemas informáticos vulnerables o recursos valiosos para atraer a los atacantes y observar sus métodos y tácticas.

- Simulación de Servicios
- Registro de Actividades
- Identificación de Amenazas
- Distracción y Desviación
- Investigación de Seguridad



Políticas de defensa perimetral

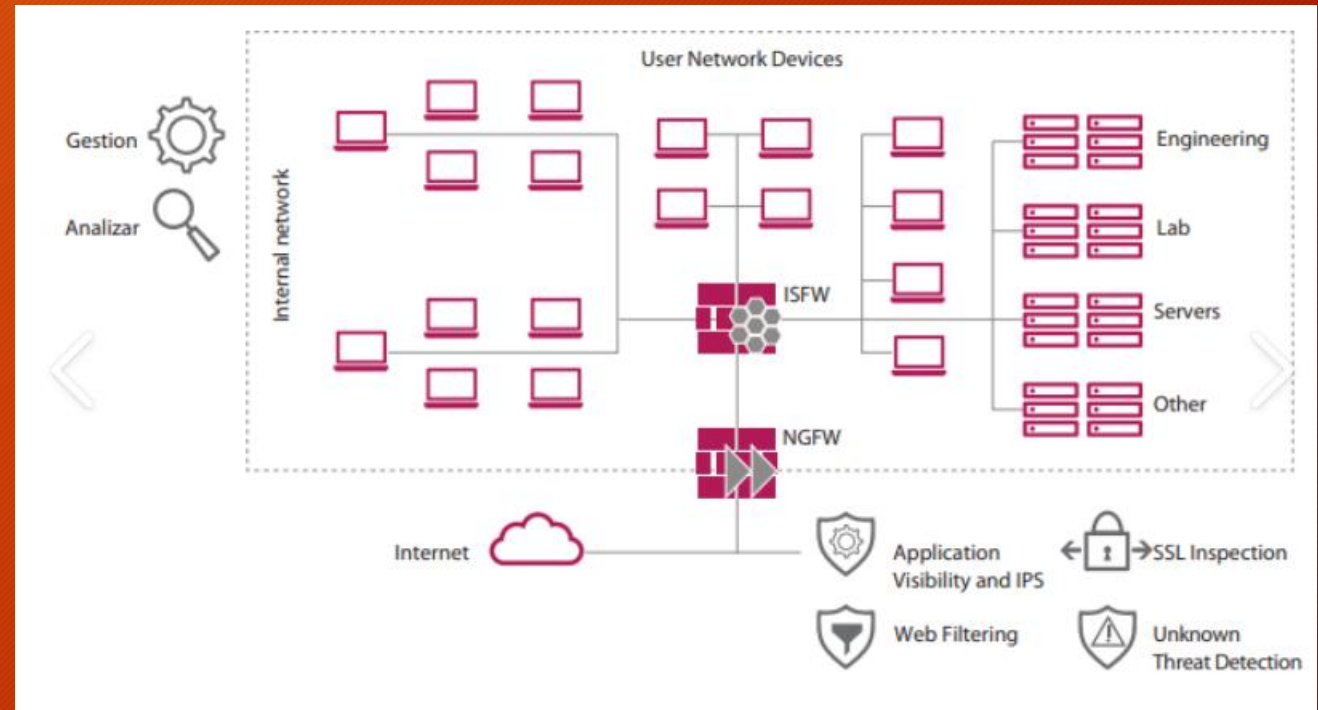
- La política de seguridad perimetral es el conjunto de normas y procedimientos que se establecen para proteger la red interna de una organización de los posibles ataques externos que provienen de Internet o de otras redes. Estas normas definen qué tipo de tráfico se permite o se deniega entre la red interna y la red externa, así como los mecanismos de seguridad que se aplican para filtrar, controlar y monitorizar ese tráfico .

Protocolos de Autenticación

- SSH (Secure hell)
- SSL/TLS (Secure Sockets Layer/Transport Layer Security)
- IPsec (Internet Protocol Security)
- LDAP (Lightweight Directory Access Protocol)
- RADIUS (Remote Authentication Dial-In User Service)
- Kerberos
- OAuth y OpenID Connect
- Tacacs y Tacacs+

Funcion de Arquitectura de Seguridad Perimetral

- Controlar el flujo de trafico entrante y saleinte de la red
- Clasificar el trafico
- Denegar conecciones



DMZ

- Una zona desmilitarizada (demilitarized zone, DMZ) es una red perimetral que protege la red de área local (local-area network, LAN) interna contra el tráfico no confiable.
- Una DMZ es una subred que se encuentra entre la Internet pública y las redes privadas. Expone los servicios externos a redes no confiables y agrega una capa adicional de seguridad para proteger los datos confidenciales almacenados en redes internas, utilizando firewalls para filtrar el tráfico.

Beneficios de Uso de DMZ

- Habilitación del control de acceso
- Prevención del reconocimiento de la red
- Bloqueo de suplantación del protocolo de Internet

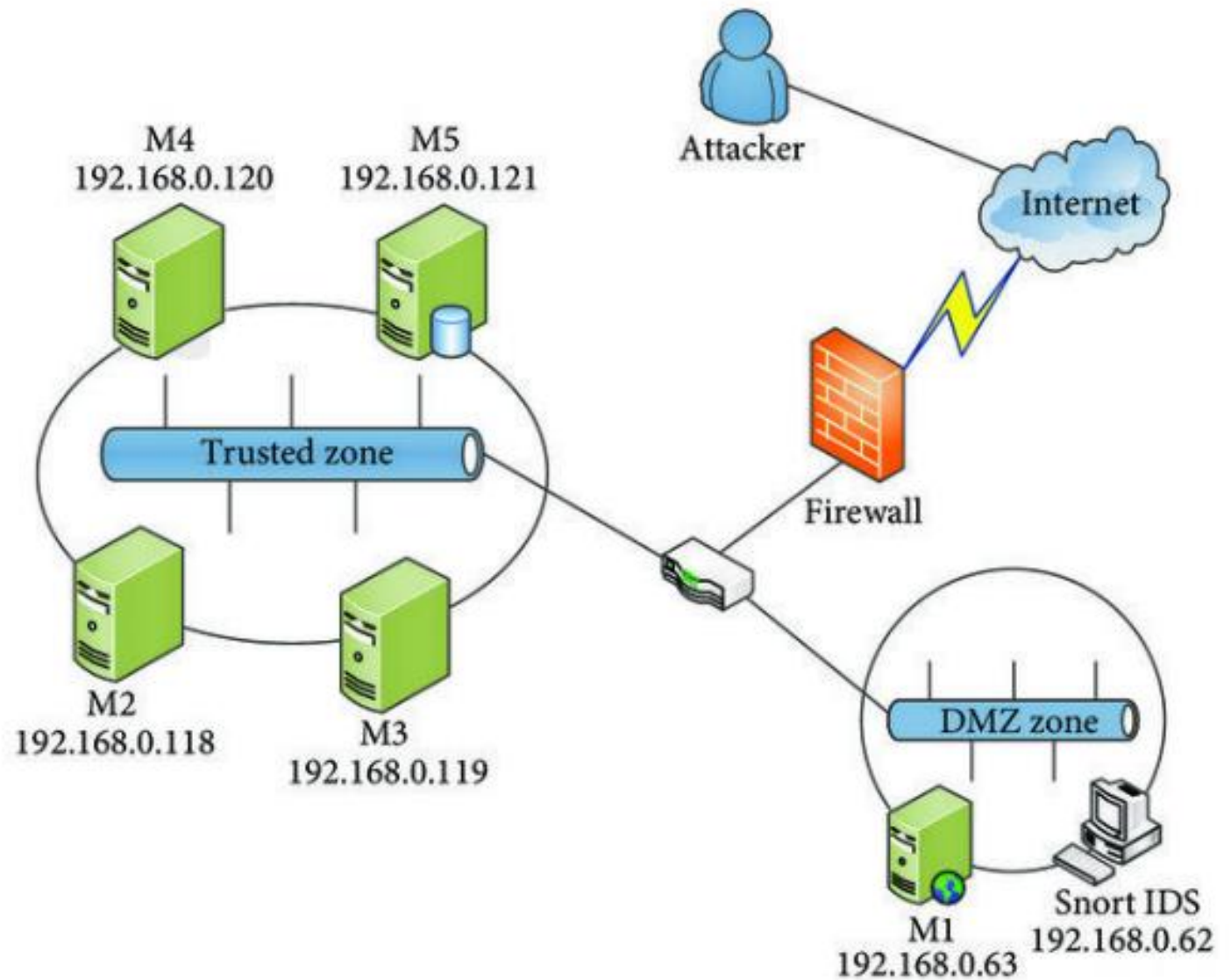
Servicios de una DMZ incluyen:

- Servidores DNS
- Servidores FTP
- Servidores de correo
- Servidores proxy
- Servidores web

Arquitectura débil de subred protegida

- La arquitectura débil de red de subred protegida consiste en colocar la DMZ detrás del firewall, de forma que el firewall tenga al menos tres interfaces: una para conectar con el exterior, otra para conectar con la DMZ y otra para conectar con la red interna². En la DMZ se ubican los servicios y recursos que deben ser accesibles desde el exterior, como el servidor web o el de correo, pero que tienen acceso limitado a la red interna.
- El firewall se encarga de filtrar el tráfico que entra y sale de la red interna, y de bloquear los paquetes que no cumplan con las reglas establecidas¹. De esta forma, se reduce el riesgo de que un atacante pueda acceder a los datos confidenciales o a los servidores internos de la organización.
- Sin embargo, esta arquitectura tiene algunas desventajas, como la dependencia de un único firewall, que puede ser un punto de fallo o de ataque, o la dificultad de gestionar las reglas de filtrado, que pueden ser muy complejas o contradictorias

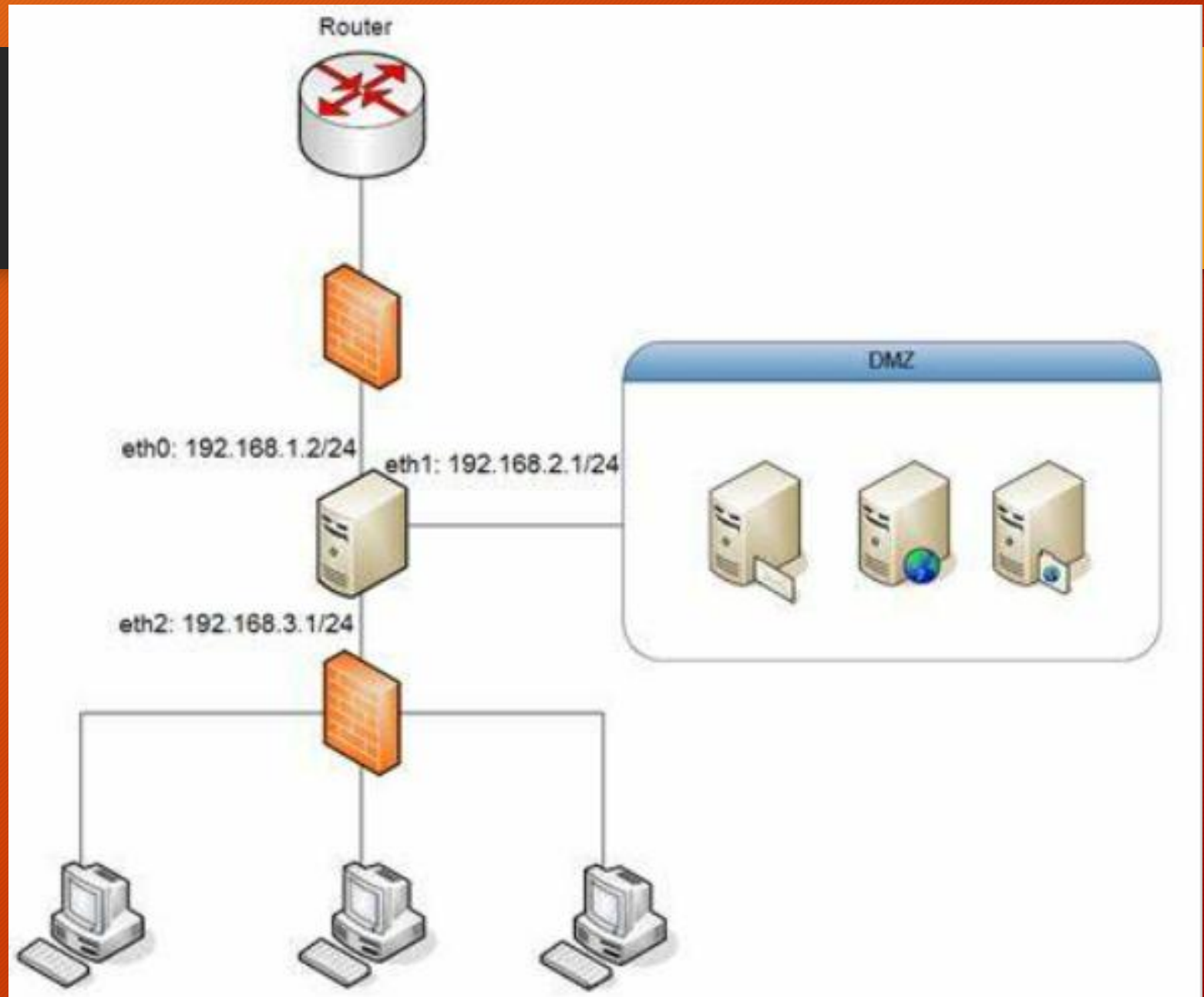
Tipos de DMZ



Arquitectura fuerte de subred protegida

- La arquitectura fuerte de subred protegida consiste en colocar la DMZ entre dos firewalls, de forma que el firewall externo se conecta a Internet y el firewall interno se conecta a la red interna². En la DMZ se ubican los servicios y recursos que deben ser accesibles desde el exterior, como el servidor web o el de correo, pero que tienen acceso limitado a la red interna¹.
- Los dos firewalls se encargan de filtrar el tráfico que entra y sale de la red interna y de la DMZ, y de bloquear los paquetes que no cumplan con las reglas establecidas¹. De esta forma, se aumenta la seguridad de la red interna, ya que se reduce el riesgo de que un atacante pueda acceder a los datos confidenciales o a los servidores internos de la organización¹.
- Esta arquitectura tiene algunas ventajas, como la mayor protección de la red interna, la mayor facilidad de gestión de las reglas de filtrado, o la mayor flexibilidad para adaptarse a las necesidades de cada servicio

Tipos de DMZ



Escenarios tipos a proteger

- Algunos escenarios típicos de sistemas con conexión a redes públicas en los que se precisa fortificar la red interna son:
- Una empresa que ofrece servicios web, correo electrónico, acceso remoto o cualquier otro servicio que requiera exponer sus servidores a Internet, y que necesita protegerlos de posibles ataques externos, como el robo de información, la suplantación de identidad, el vandalismo o la denegación de servicio.
- Una organización que tiene varias sedes o sucursales distribuidas geográficamente, y que necesita interconectarlas mediante una red privada virtual (VPN) que garantice la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellas.
- Un usuario doméstico que utiliza una red inalámbrica para conectarse a Internet, y que necesita evitar que intrusos accedan a su red o a sus dispositivos, o que utilicen su conexión para fines ilícitos, como el envío de spam, la descarga de contenido ilegal o la realización de ataques a otros sistemas.

Seguridad Perimetral de Empresas Distribuidas

La seguridad perimetral en empresas distribuidas se refiere a la protección de las redes y los sistemas informáticos de las organizaciones que tienen varias sedes o sucursales en diferentes ubicaciones geográficas, y que necesitan interconectarlas de forma segura y eficiente.

La seguridad perimetral en empresas distribuidas implica el uso de diferentes medidas y tecnologías, como los cortafuegos, las redes virtuales privadas (VPN), los sistemas de detección y prevención de intrusiones (IDS/IPS), los controles de acceso e identidad, o los sistemas anti-DDoS. Estas medidas tienen como objetivo restringir o controlar el tráfico que entra o sale de las redes internas de cada sede o sucursal, así como detectar y bloquear las amenazas o los ataques que provienen de Internet o de otras redes externas.

Seguridad Perimetral en la Nube

- La seguridad perimetral en la nube se refiere a la protección de los recursos y los datos que se encuentran alojados en servidores remotos accesibles mediante Internet, y que son utilizados por las organizaciones para agilizar sus operaciones. La seguridad perimetral en la nube implica el uso de diferentes medidas y tecnologías, como los firewalls, las redes virtuales privadas (VPN), los sistemas de detección y prevención de intrusiones (IDS/IPS), los controles de acceso e identidad, o los sistemas anti-DDoS. Estas medidas tienen como objetivo restringir o controlar el tráfico que entra o sale de los recursos en la nube, así como detectar y bloquear las amenazas o los ataques que provienen de Internet o de otras redes externas.

Clasificación de zonas de riesgo LAN

- Zona interna: es la zona más segura de la red, donde se ubican los recursos y servicios más críticos y confidenciales de la organización, como los servidores de bases de datos, los sistemas de gestión, los archivos, etc. Esta zona tiene acceso restringido y controlado a los usuarios autorizados, y se protege mediante firewalls, sistemas de detección y prevención de intrusiones, controles de acceso e identidad, cifrado de datos, etc.
- Zona desmilitarizada (DMZ): es una zona intermedia entre la zona interna y la zona externa, donde se ubican los recursos y servicios que deben ser accesibles desde el exterior, pero que tienen acceso limitado a la zona interna, como el servidor web, el de correo, el de acceso remoto, etc. Esta zona se aísla mediante firewalls u otros dispositivos de seguridad que filtran el tráfico entre la DMZ y la zona interna o externa. El objetivo de la DMZ es reducir el riesgo de que un atacante pueda acceder a los recursos de la zona interna desde el exterior.
- Zona externa: es la zona más expuesta de la red, donde se ubican los recursos y servicios que se conectan directamente a Internet o a otras redes públicas, como los routers, los módems, los proxies, etc. Esta zona tiene acceso abierto y no controlado a los usuarios externos, y se protege mediante firewalls, sistemas anti-DDoS, honeypots, etc.

Clasificación de zonas de riesgo WAN

- Zona segura: es la zona donde se ubican las redes locales de las diferentes sedes o sucursales de la organización, que se interconectan mediante una red privada virtual (VPN) que garantiza la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellas. Esta zona se protege mediante firewalls, sistemas de detección y prevención de intrusiones, controles de acceso e identidad, cifrado de las comunicaciones, etc.
- Zona insegura: es la zona donde se ubican los recursos y servicios que se conectan a Internet o a otras redes públicas, como los routers, los módems, los proxies, etc. Esta zona tiene acceso abierto y no controlado a los usuarios externos, y se protege mediante firewalls, sistemas anti-DDoS, honeypots, etc.

Clasificación de zonas de riesgo WLAN

- Zona segura: es la zona donde se ubican los recursos y servicios que se conectan a la red inalámbrica mediante un punto de acceso que implementa protocolos de seguridad, como WPA2, que garantizan la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellos. Esta zona se protege mediante firewalls, sistemas de detección y prevención de intrusiones, controles de acceso e identidad, cifrado de las comunicaciones, etc.
- Zona insegura: es la zona donde se ubican los recursos y servicios que se conectan a la red inalámbrica mediante un punto de acceso que no implementa protocolos de seguridad, o que los implementa de forma débil, como WEP, que no garantizan la seguridad, la confidencialidad y la integridad de las comunicaciones entre ellos. Esta zona tiene acceso abierto y no controlado a los usuarios externos, y se protege mediante firewalls, sistemas anti-DDoS, honeypots, etc.